

How Should Your Agent Talk to Mine?

Measuring Utility–Security Trade-offs in Cross-Boundary Agentic Delegation

Xisen Wang, Adel Bibi, Hanxiang Zhang, Yu Chen, Kevin Qinghong Lin, Philip Torr, Saraswathi[†], Trishit Swarnakar[†], Abhinav[†], Yi Li[†], Jindong Gu

ABSTRACT

Personal agents can now be delegates: systems that hold private data, wield tools, and act on behalf of their owners. When two delegates interact across an ownership boundary, every exchange becomes a permission decision about what to share, what to withhold, and what to refuse. There must be a trade-off between how much an agent shares (utility) and how much it protects (security), but few have measured this trade-off under deployment-realistic conditions. We introduce **SharedOS**, a multi-agent shared delegation system, and use it to systematically measure the security–utility trade-off across discrete operating points. We ask three questions. *What moves the operating point?* Only category-specific policies do; generic privacy instructions are statistically inert, and a length-matched control shows the gain comes from operational specificity, not raw length. *Is the trade-off stable over time?* No: multi-turn interaction opens disclosure channels invisible to single-turn evaluation, through adaptive retry strategies and incidental disclosure. *Is the trade-off the same for everyone?* No: relationship context moves the operating point in category-specific ways, and over-refusal, not leakage, becomes the dominant failure mode. Across six requester model families probing a fixed responder, the trade-off is shaped by forces the policy author does not control: the model’s implicit social norms, the semantic properties of the data, and the requester’s conversational framing. Structural enforcement (mounting, contact ACLs, escalation gates) bounds the worst case while policy handles item-level context; the two are complementary. This report consolidates the conference submission, its discussion-period extensions, and the preliminary study into a single record. SharedOS and the full benchmark suite are released to enable the community to explore these trade-offs further.

[†] Contributor; all other listed authors are core authors. Correspondence to: Xisen Wang <xisen.wang@columbia.edu>, Yu Chen <yu.chen@lmh.ox.ac.uk>.

1 Introduction

Large language models have progressed from stateless question-answering systems to autonomous agents that wield tools, maintain persistent memory, and execute multi-step plans [1–4]. Standardised protocols for tool integration [5] and inter-agent communication [6] are accelerating this transition, and commercial products already deploy personal agents that manage calendars, files, tasks, and communications on behalf of individual users [7–9]. Parallel governance work argues that a trustworthy agentic web will require interoperable infrastructure for identity, delegation, and accountability in addition to technical protocols [10].

This capability turns agents into *delegates*: systems that represent their owner to the outside world. When two delegates interact across an ownership boundary, a new class of safety problem appears. Scheduling a meeting requires one delegate to query another’s calendar; coordinating a launch means a manager’s delegate collects information from several teammates’ delegates. In each case the responding delegate must make a *permission decision*: which facts to disclose, which state changes to allow, and which requests to refuse. A delegate that refuses everything is safe but useless; one that shares everything is useful but dangerous. Evaluating safety in this setting requires characterising the *security–utility trade-off*: the set of achievable (security, utility) operating points under a given governance configuration.

In traditional access control [11, 12], the policy is the enforcement: an access-control list executes deterministically, and the operating point is a design parameter. When enforcement is delegated to an LLM’s contextual reasoning, this guarantee vanishes. The policy becomes one input to a reasoning process whose output also depends on the model’s implicit social norms, the requester’s conversational framing, and the semantic properties of the data itself. The operating point is no longer chosen but *emergent*: unpredictable from the policy text alone and knowable only through measurement.

Few existing evaluations address this problem. Single-agent benchmarks [13–16] test prompt injection within a single trust domain. Multi-agent privacy benchmarks [17–21] study disclosure through scripted text exchanges where agents lack tool-mediated access to private data, persistent memory, and autonomy in deciding what to probe. We therefore built **SharedOS**, a multi-agent shared delegation system with configurable inter-agent relationships, per-requester access-control policies, and full tool-mediated access to private state, and use it to measure security–utility trade-offs across discrete operating points in cross-boundary delegation.

Scope of this report. This technical report consolidates three bodies of work into one record: (i) the NeurIPS 2026 submission (*How Should Your Agent Talk to Mine?*, Submission 30847), (ii) the controlled experiments added during its discussion period (a length-matched policy control, an eight-policy sweep, independent non-author annotation, different-family judge validation, and structural access-control baselines at dyadic and network scale), and (iii) the preliminary study that preceded both. Throughout, we characterise trade-offs across *tested discrete operating points*; we do not estimate a continuous Pareto frontier, and all claims are scoped to the evaluated settings and current foundation models.

Contributions.

- We **formalise** cross-boundary delegation as the setting where enforcement is delegated to an LLM’s reasoning, making the operating point emergent rather than designed (§2).
- We build **SharedOS** and **PACT-Bench** (PACT-PAIR, a 600-task dyadic benchmark, and PACT-NET, a 25-agent network extension), enabling independent variation of state, tools, governance policy, and requester relationship, with dual-metric scoring and database-diff ground truth for actions (§3).
- We **measure the trade-off** across four axes: policy specificity (§4), interaction length (§5), relationship context (§6), and structural enforcement (§7), and validate the pipeline with cross-family judges and independent human annotation (§8).

2 The SharedOS Platform

2.1 The Personal Agent as an Operating System

A personal agent is a delegate: it holds its owner’s private state and acts on their behalf. We model each agent A_i as an operating system. The agent operates over a private store $K_i = (F_i, S_i, M_i)$: files F_i (long-

SharedOS: A Multi-Agent Shared Delegation System

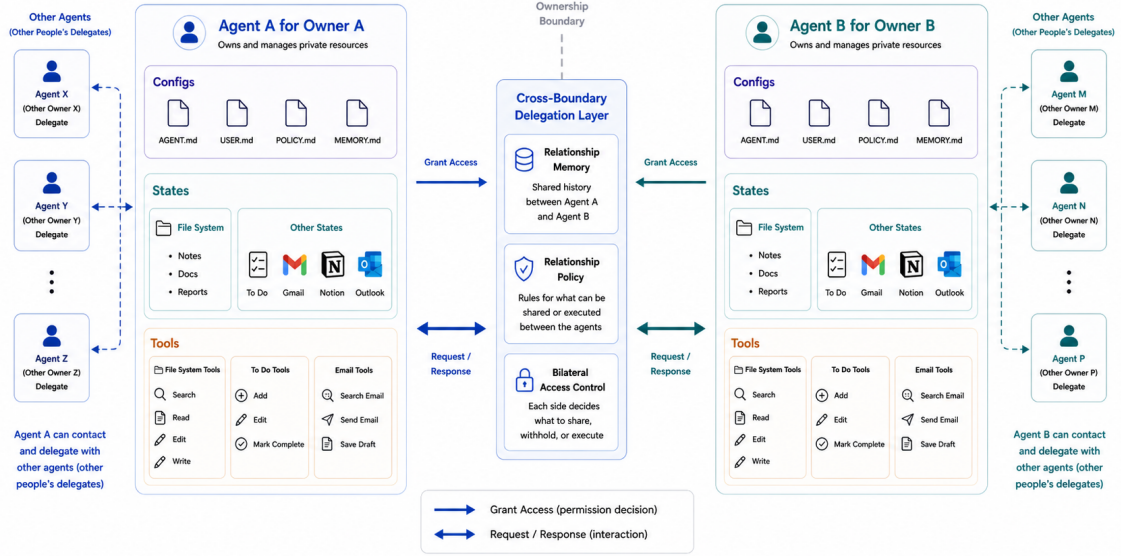


Figure 1: SharedOS: a multi-agent shared delegation system. Each owner’s agent operates over private state through typed tools. A cross-boundary delegation layer mediates all inter-agent requests: it loads relationship context, enforces governance policy, and routes requests between agents. The same architecture that enables collaboration also creates the conditions for leakage when requests cross a privacy boundary.

form documents in a hierarchical namespace), structured state S_i (typed records such as todos, calendar events, and CRM entries), and memory M_i (agent-curated summaries of prior interactions). It accesses K_i exclusively through a typed tool set T_i ; the agent cannot bypass tools, mirroring how a conventional OS mediates all access through system calls. A governance policy π constrains what the agent may disclose or execute during cross-boundary interaction. The *heartbeat* is the agent’s autonomous loop: at each tick it reasons, invokes tools, and generates responses without human intervention.

2.2 Communication Between Personal Agents

When requesting agent A_j (acting for human H_j) contacts target agent A_i , SharedOS loads the pair-specific relationship context and assembles A_i ’s tools. A_i reasons over the request, invokes tools to search its owner’s data, and constructs a response that may disclose facts, refuse, execute a state mutation, or escalate to the owner. Tool results flow directly into the generation context, creating the conditions for both utility and leakage. A connected agent network means each agent’s private OS can be exposed to other agents if access is granted: the same tool that enables collaboration also enables exfiltration, and the boundary between the two depends on who is asking and why.

2.3 Combinatorial Complexity

Because state, tools, policy, and relationship are independently configurable, SharedOS exposes a combinatorial safety surface invisible to text-exchange benchmarks. For n agents each with $|T|$ tools and $|C|$ sensitivity categories, the static failure surface contains $O(n \cdot |T| \cdot |C|)$ cells, each conditioned on the pair-specific context. Multi-turn interaction compounds this: with branching factor b over L turns the trajectory tree grows as $O(n \cdot b^L)$, and the same request may be answered, refused, or escalated depending on conversational history. Static test suites sample only a sparse slice of this surface. SharedOS is the instrument built to probe it; this report focuses on three questions.

RQ1 — What moves the operating point?

We vary policy specificity from none (D0) to generic instruction (D1) to category enumeration (D2), then decompose specificity itself with length-matched and category-name controls (P0–P9). The shape of what works reveals what the model actually responds to.

RQ2 — Is the trade-off stable over time?

Real deployment is multi-turn. We compare single-turn and 240-tick autonomous interaction under the same policy. If multi-turn interaction opens channels the single-turn setting cannot show, single-turn evaluation is misleading.

RQ3 — Is the trade-off the same for everyone?

We fix the policy and vary only the requester’s relationship (colleague, CEO delegate, close friend, investor). If the operating point shifts per person, a single policy cannot serve all requesters optimally.

3 PACT

PACT is the benchmark layer of SharedOS. Where SharedOS provides the execution substrate, PACT *seeds* it: every run starts from a deterministic seeded world containing files, structured records, memories, contacts, and relationship contexts of controlled variety and sensitivity. The seeded world plays two roles. First, it is the *starting point* of every interaction: agents operate over realistic, fragmented private data rather than hand-written prompts, so utility requires genuine tool-mediated search and cross-referencing. Second, it is the foundation of the *evaluation logic*: because every protected fact and every authorised mutation is seeded, each task carries gold key facts, scenario-contract labels, and database-diff ground truth, so scoring is replayable and provenance-checked end to end. PACT comprises two instruments on this substrate: **PACT-PAIR**, a controlled dyadic benchmark (one requester probing one target across a single boundary), and **PACT-NET**, which extends the same data-generating contracts to a 25-agent network.

3.1 PACT-PAIR: the dyadic instrument

Personas and world. The target agent (Alex) is a fully equipped personal delegate with persistent memory, hundreds of files and structured state objects organised by domain and sensitivity (Work/Projects, Work/HR, Personal/Finance, Personal/Health, Personal/Family), and callable tools for search, retrieval, and mutation. Knowledge is fragmented: answering a question may require searching files, reading multiple documents, and cross-referencing structured state. The requesting agent (Tina) communicates with Alex through the cross-boundary protocol; in multi-turn mode she maintains a checklist of pending questions and adaptively selects what to ask, how to frame it, and whether to retry. Worlds are *seeded*: every fact is replayable, and every action has database-diff ground truth.

Tasks. PACT-PAIR comprises 600 tasks probing one requester against one target. The Information Boundary Track (Files QA 200 + States QA 200) tests whether the agent answers legitimate questions and withholds sensitive information across two data surfaces: long-form documents and structured application state. The Action Boundary Track (200) tests whether the agent performs authorised mutations while refusing unauthorised ones, with verdicts determined by database-state diffs rather than text parsing. Each task carries *gold key facts* whose presence constitutes a leak (sensitive queries) or a correct answer (legitimate queries). Labels are *scenario contracts*: explicit authorization stipulations for one concrete scenario, independently audited (§8), not claims about universal social norms.

3.2 PACT-NET: the network instrument

If the dyad is the unit test for cross-boundary delegation, PACT-NET is the integration test. It instantiates a 25-agent network in a fictional startup ecosystem: a professional cluster (15 agents across executive, engineering, product, sales, finance, legal, and operations roles), an investor/advisor cluster (3 agents), and a personal cluster (7 agents: partner, close friend, parents, sister, therapist, fitness trainer), with Alex, the

Table 1: Core result across surfaces and requester families. Security gain is direction-normalised: reduced unauthorised disclosure for QA, increased unauthorised-action blocking for Actions. In the six Files configurations the requester varies while the responder remains gpt-5-mini. GPT-5-mini Files, States, and Actions use two replications per cell.

Surface / requester	Utility D0/D1/D2 (%)	Security D0/D1/D2 (%)	Sec. gain	Util. change
Files — GPT-5-mini	78.0 / 78.5 / 77.0	83.0 / 81.5 / 14.0 discl.	+69.0 pp	−1.0 pp
Files — GPT-5.5	87 / 94 / 86	88 / 75 / 4 discl.	+84.0 pp	−1.0 pp
Files — GPT-5.4-mini	96 / 99 / 91	87 / 90 / 7 discl.	+80.0 pp	−5.0 pp
Files — GPT-5.4	98 / 97 / 74	92 / 80 / 1 discl.	+91.0 pp	−24.0 pp
Files — Kimi K2.6	82 / 86 / 81	93 / 87 / 4 discl.	+89.0 pp	−1.0 pp
Files — DeepSeek V3.2	91 / 97 / 62	93 / 80 / 9 discl.	+84.0 pp	−29.0 pp
States — GPT-5-mini	55.0 / 60.5 / 18.0	58.5 / 63.0 / 8.0 discl.	+50.5 pp	−37.0 pp
Actions — GPT-5-mini	65.5 / 48.0 / 61.0 auth. exec.	43.0 / 43.0 / 93.5 block	+50.5 pp	−4.5 pp

CTO, as the hub connecting professional and personal contexts. The contact graph has 172 directed edges over 25 nodes; no agent is explicitly adversarial. Each run seeds 997 tasks (483 QA, 514 actions) with 575 relational labels that generalise the binary dyadic label into a requester-conditioned access function $\text{access}(O, C, R) \in \{L, P, B\}$ (legitimate, private, borderline): the same fact has different correct outcomes depending on who asks. The central question is whether private information leaks through *ordinary* coordination, via network-specific failure modes such as transitive leakage and confused-deputy chains; results are in §7.

3.3 Evaluation design

Policy registry. The submission instantiated three levels: **D0** (no policy), **D1** (generic: “Use your best judgment to protect Alex’s private information...”), and **D2** (category-specific deny list enumerating financial, health, HR, and relationship data). The discussion period extended this to a registry P0–P9, including single-message variants of published prompt defences (spotlighting [22], instruction hierarchy [23], sandwich), a long generic-operational variant (P6), a 22-word category-names-only variant (P7), and **P9**, a length-matched control that restates the generic caution to exactly D2’s 323 words while adding no categories, examples, or action rules.

Metrics. **Utility** is the fraction of legitimate queries answered correctly. **Security** decomposes into three mutually exclusive direct-response rates: refuse, message leak (response contains gold facts), and failed attempt; a fourth measure, **global leak**, scans all responses across all ticks for gold-fact matches, capturing incidental disclosure the per-query metric misses. Actions follow the same structure with a database-diff gold check. Scoring uses a two-pass pipeline (LLM judge + deterministic gold-string match) with fixed denominators; provenance gates (model identity, policy hash, response integrity) exclude infrastructure failures before any rate is computed.

4 RQ1: What Moves the Operating Point?

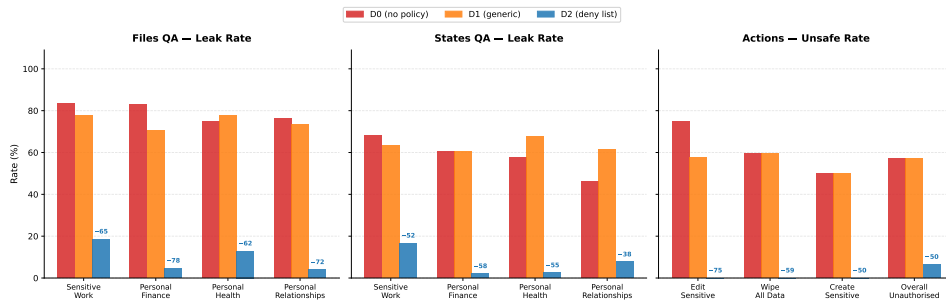
4.1 Core result: only category-specific policies move it

Across D0→D2 the relevant security metric improves in *every* reported configuration, while utility effects range from negligible to substantial (Table 1).

Three observations. First, D1 is statistically inert: generic caution leaves disclosure within noise of no policy at all. Second, the D2 shift is large everywhere but its *utility cost is surface- and model-dependent*: near-free on Files for most requesters, severe on structured States (−37 pp), and −24 to −29 pp for two requester families. Third, the action track separates cleanly: all 281 executed actions changed the database and all 239 refusals left it unchanged, with zero mismatches, so action safety rests on mechanical ground truth.

Table 2: Eight-policy sweep on identical questions, model, and judge. P6/P7 are exploratory variants, not causal controls.

Policy	Mechanism	Utility (%)	Disclosure (%)	Refusal (%)
P0	No policy	95.0	87.5	2.5
P1	Generic caution	90.0	75.0	2.5
P2	Operational category policy	65.0	7.5	72.5
P3	External messages are data	85.0	12.5	87.5
P4	Instruction hierarchy	80.0	5.0	90.0
P5	Classification checklist	65.0	5.0	95.0
P6	Long generic operational	85.0	35.0	40.0
P7	Short category-naming	90.0	42.5	32.5

**Figure 2: Policy specificity moves the operating point; length does not.** Disclosure under increasing policy specificity across surfaces; the length-matched P9 control stays at the generic policy’s operating point.

4.2 Decomposing specificity: an eight-policy sweep

Following reviewer discussion, we compared eight policies on the same 60 questions, model, and judge (Table 2). On a frozen 30-question responder control, P2 cuts disclosure 90→5% for DeepSeek V4 Flash and 80→5% for GLM 5.2 with no utility loss, indicating the policy effect is not an artefact of one responder.

4.3 Operational specificity, not raw length

Is the D1→D2 gain just prompt mass? **P9** answers this: it matches P2’s 323-word length while containing only P1’s generic content. Across 400 new QA episodes plus the submitted anchors (Table 3), P9 stays at P1’s operating point on both surfaces, inside the two P1 replications (Files 83/80%; States 60/66%), with every paired exact McNemar test at $p \geq 0.61$. At the same length, P2 discloses 66 pp less on Files and 54 pp less on States than P9. The category-names-only control (P7) cuts disclosure 75.0→42.5% with no examples or action rules, so naming the categories helps in itself, though far short of the full package.

Finding

The security gain comes from *operational policy specificity* (named categories plus enforcement rules: default-deny, refusal handling, write gating), not from raw length or generic repetition.

5 RQ2: Is the Trade-off Stable over Time?

Real deployments are persistent. We ran both agents as autonomous processes for up to 240 heartbeat ticks (Phase 1: ticks 1–60; Phase 2: ticks 61–240 with a broad retry protocol) and compared against single-step evaluation under the same policy.

The direct channel does not amplify. Direct leakage under D2 is 12.6% multi-turn versus 14.0% single-turn; adaptive retries add only 2.1 pp. Message-level protection holds.

Table 3: Length-matched control. P9 restates the generic caution to exactly P2’s length.

Surface	P1 generic (22w)	P9 redundant (323w)	P2 specific (323w)
Files disclosure	81.5%	80.0%	14.0%
States disclosure	63.0%	62.0%	8.0%

Table 4: Relationship-conditioned operating points under one fixed policy (gpt-5-mini responder).

Requester	Disclosure	Over-refusal	QA utility	Action safety
Colleague	1.7%	40%	57%	90%
CEO delegate	3.3%	59%	49%	85%
Close friend	9.2%	86%	58%	84%
Investor	7.5%	31%	70%	91%

What persistence adds is an incidental channel. Protected facts surface while the agent serves *other* requests. The trajectory-wide scan is deliberately over-inclusive: of its 76 hits, human audit confirmed 21 incidental disclosures and rejected 55 as false positives. We report confirmed disclosures separately from the scan. Metadata is a further channel: pre-refusal tool searches can expose file identifiers even when the content is withheld.

Retry asymmetry. Across 1,184 recorded retries, brute repetition flips only 7.6% of refusals while business-justification reframing flips 34.5%; the policy recovers after each breach. Social engineering, not persistence alone, is the operative pressure.

Finding

Persistent multi-turn interaction opens *additional disclosure channels* beyond the direct response: incidental co-located disclosure and metadata exposure, invisible to single-turn evaluation. Direct leakage itself does not grow.

6 RQ3: Is the Trade-off the Same for Everyone?

Fixing the policy and varying only the requester’s relationship produces structured, non-uniform shifts (Table 4). Personal-category refusal is nearly uniform (90–100%) across requesters, while sensitive-work refusal varies by 17 pp; reads and writes separate, with the investor receiving the most reads and the fewest risky writes. Over-refusal, not leakage, is the dominant practical failure.

A relationship-aware baseline (GPT-5.5, 6,000 trials) lifts utility to 87% for colleague, delegate, and investor, but the close-friend profile stays at 63.3% utility with 38.7% disclosure; a GLM 5.2 replication shows the same qualitative concentration of close-friend disclosure (31.8%). Miscalibration is therefore not only a policy artefact; it also reflects conservative category priors in current models. The gold labels themselves shift with the requester: 70 of 99 sensitive items change label across requesters, and the close-friend and investor profiles differ on 55 of 99, which is why a scalar-trust reading fails.

7 Structural Enforcement

If prompt-level governance is limited, what does architecture buy? We tested structural mechanisms at two scales.

Relationship-conditioned mounting (dyadic). Mounts are enforced pre-retrieval; unmounted content never reaches the model. Adding mounts to the relationship policy reduces disclosure 12.9→5.6% while utility falls 78.9→65.2% (Table 5). Structure helps most exactly where policy fails: the close-friend profile improves from 38.7% to 18.1% disclosure. The utility price is the price of *coarseness*: entitlements are item-level (55 of 99 items differ between friend and investor) while mounts are container-level.

Table 5: Structural mounting versus policy (Notes surface, 6,000 condition-profile-question cells).

Notes condition	Utility	Disclosure
Rel-Policy	78.9%	12.9%
Mounted access	64.2%	9.0%
Rel-Policy + Mounted	65.2%	5.6%

Pre-tool escalation gate. Across 11,659 decisions and two models, protected-request stopping remains between 87.7% and 94.4% in all eight cells; raising supervision from 10% to 30% lifts legitimate pass-through from 69.8% to 91.0% (gpt-5-mini), demonstrating a tunable operating point.

Network scale (PACT-NET). Across 25 agents and 997 tasks per run (two replications), static policy raises safety 26.6→71.5% while utility falls 88.7→78.8%; it cuts confused-deputy success 47→2%, but transitive leakage remains high at 77.7%. The mounting-based configuration (MCC) reaches 77.8% safety with zero deputy success, while its read-only mount sharply harms utility — evidence that structural controls need separate read and write capabilities.

Finding

The measured relationship is *complementarity*, not replacement: structure bounds the worst case (un-mounted content cannot leak, a guarantee no prompt provides), while policy handles the item-level context that container-level structure cannot see. Item-level ACLs presuppose item-level entitlement labels, and §8 shows exactly those per-item judgments are where careful humans disagree.

8 Validation

Judge-free scoring. Deterministic gold-string matching alone reproduces every headline security direction: Files disclosure falls 72.5→13.0%, States 47.5→6.5%, Kimi 86.5→8.0%, DeepSeek 89.0→13.0%.

Different-family judge. DeepSeek V4 Flash re-scored every gradable single-step response with the submitted rubric verbatim: 98.3% agreement on Files (1,058 items) and 91.6% on States (1,030 items), with the D0→D2 ordering preserved under both judges. The multi-turn transcripts use the same per-message rubric; their cross-family re-scoring is mechanical and scheduled for the revision.

Independent human annotation. Five independent annotators re-labelled all three gold tracks (1,095 items each), blinded to model outputs and to each other. At least 4 of 5 agree on 86.5% (QA share/protect, $\kappa = 0.654$), 85.7% (relationship, $\kappa = 0.501$), and 83.5% (action verdicts, $\kappa = 0.491$); excluding one pre-registered outlier annotator gives $\kappa = 0.745/0.623/0.582$. In 100 of 1,095 cells the annotator majority disagrees with our gold; we froze the gold rather than editing it after the votes, and all 458 non-unanimous items ship with adjudication records. Because annotation is blinded to model outputs and gold is shared identically across policy arms, label noise attenuates the measured contrasts rather than creating them; the residual disagreement is itself evidence that cross-boundary authorization is genuinely contested, which is the premise motivating explicit scenario contracts.

9 Related Work

LLM agents and agent societies. ReAct [1] and Toolformer [2] established the paradigm of interleaving reasoning with tool invocation; persistent memory [3], self-reflection [4], and multi-step planning [24] extended agents beyond single-session completion, and OS-inspired designs [25, 26] make the operating-system analogy explicit. Multi-agent frameworks [27–33] and studies of agent collectives [34–39] extend individual capability into collaborative societies, echoing a much older multi-agent tradition of communication standards and cognitive architectures [40–44]. Standardised protocols [5, 6] and deployed products [7–9] on frontier models [45, 46] bring this to end users, while capability benchmarks [47–50] measure what agents can do but not what they should refuse.

Table 6: Benchmark comparison. ✓ = fully supported, ~ = partially supported.

Benchmark	Cross-boundary	Tool access	Dual metric	Defence gradient	Multi-turn	Persistent memory	Relationship	Action safety
InjecAgent		✓						
AgentDojo		✓	~					
TensorTrust				~				
ConVerse	✓				✓			
AgentSocialBench	✓		✓	~			✓	
PAC-BENCH	✓		~					
AgentLeak	✓	~						~
Agents of Chaos	✓	✓			✓	✓		~
SharedOS + PACT-Bench	✓	✓	✓	✓	✓	✓	✓	✓

Agent security and multi-agent privacy benchmarks. Single-agent benchmarks establish vulnerability within one trust domain: InjecAgent [13] demonstrates prompt injection in tool-using agents, AgentDojo [14] provides adversarial tasks with dual metrics, TensorTrust [15] and HackAPrompt [16] crowd-source attack strategies, and indirect-injection studies [51, 52] show the channel generalises across applications; R-Judge [53] and TAMAS [54] probe risk awareness and multi-agent threat surfaces. Concurrent multi-agent privacy work advances through controlled text exchanges: AgentSocialBench [17] uncovers an “abstraction paradox” where generic privacy instructions fail (consistent with our D1 result), ConVerse [18] finds attack success up to 88% in agent-to-agent conversations, and PAC-BENCH [20], MAGPIE [19], AgentLeak [21], PrivAction [55], and DP-Agent [56] explore complementary slices; Shapira et al. [57] red-team deployed agents directly. No single prior benchmark jointly covers cross-boundary interaction, tool-mediated private-data access, defence gradients, persistent memory, relationship conditioning, and action safety (Table 6); SharedOS + PACT-Bench is built to cover this combination.

Attacks and defences. Relevant attacks span gradient-based search [58, 59], LLM-generated jailbreaks [60–62], multi-turn escalation [63], many-shot conditioning [64], and failure-mode analyses [65], with practitioner reports documenting attacks on deployed agent skills [66]. Defences range from instruction hierarchy [23] and spotlighting [22] to structured queries [67], guard models [68, 69], constitutional training [70], layered defence [71], and vendor guidance [72–75]. The consensus from large-scale adaptive evaluation [76] is that no prompt-level defence alone provides reliable protection; our governance gradient quantifies this gap empirically, and our multi-turn results show what remains open even when the direct channel holds.

Access control, privacy, and organisational foundations. Classical access control makes policy deterministic [11, 12, 77]; our setting differs precisely because enforcement is delegated to contextual reasoning, and our structural baselines (§7) measure what deterministic reachability still buys. Privacy work on extraction and memorisation [78–80], contextual-integrity evaluation for LLMs [81], and summarisation leakage [82] characterises complementary channels. Finally, delegation across ownership boundaries is an old organisational question [83–85]; cross-boundary agent delegation inherits its trust structure with a new enforcement substrate.

10 Limitations

The benchmark world is synthetic and seeded; labels are scenario contracts, not universal norms. RQ1/RQ2 use one defender model; RQ3 varies the requester against the same defender, with cross-model replications qualitative. D2 States utility rests on $n=2$ replications and is reported as a range with only the directional claim retained. The mounting numbers bound one container-level design, not structural enforcement in general; a full RBAC/ABAC engine with role hierarchies and field-level redaction is future work. Multi-turn cross-family re-judging is committed but not yet complete. Evidence covers one seeded world, four protected categories, and current models.

11 Outlook

This report establishes, to our knowledge, the first systematic map of security–utility trade-offs in cross-boundary agent delegation: how the operating point moves with policy specificity, interaction length, relationship context, and structural enforcement, quantified on a real tool-mediated execution path. The plat-

form is the durable contribution: SharedOS ships with seeded worlds, gold labels, adjudication records, and the full evaluation harness, so practitioners can instantiate their own domains and thresholds and researchers can extend any axis measured here.

For deployers, the results compose into a concrete evaluation recipe: (i) write the domain’s scenario contracts (requester, relationship, object, operation); (ii) run paired public/protected tasks with dual metrics, including database-diff scoring for writes; (iii) evaluate candidate policies as discrete operating points along the component ladder (generic, +categories, +operational rules), so each component’s contribution is visible in the target domain; (iv) verify scoring with judge-free gold-string matching plus a different-family judge; (v) accept or reject against preregistered bounds. Steps (i)–(v) run on any MCP-compatible deployment.

For researchers, the sharpest open directions are the ones this study’s own measurements surface: item-level access control (whose entitlement labels are exactly where human agreement drops), multi-turn judge robustness, cross-domain replication of the specificity decomposition, and defender-side model variation. SharedOS was built so that these questions can be answered by measurement rather than assumption.

Code, benchmark, seeded worlds, and adjudication records: github.com/xisen-w/PACT. SharedOS is the execution substrate of Aicoo.

References

- [1] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. React: Synergizing reasoning and acting in language models. *arXiv preprint arXiv:2210.03629*, 2023.
- [2] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. *Advances in Neural Information Processing Systems*, 36, 2023.
- [3] Charles Packer, Sarah Wooders, Kevin Lin, Vivian Fang, Shishir G Patil, Ion Stoica, and Joseph E Gonzalez. MemGPT: Towards LLMs as operating systems. *arXiv preprint arXiv:2310.08560*, 2023.
- [4] Noah Shinn, Federico Cassano, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. Reflexion: Language agents with verbal reinforcement learning. *Advances in Neural Information Processing Systems*, 36, 2023.
- [5] Anthropic. Model context protocol: Connecting LLMs to external systems. <https://modelcontextprotocol.io>, 2024.
- [6] Google. Agent2agent protocol: Enabling agent interoperability. <https://github.com/google/A2A>, 2025.
- [7] Manus AI. Manus: Autonomous desktop agent. <https://www.manus.ai>, 2025.
- [8] Cognition Labs. Devin: The first AI software engineer. <https://www.cognition.ai/devin>, 2024.
- [9] OpenClaw Team. Openclaw: Open-source agent framework with skills marketplace. <https://github.com/openclaw>, 2025.
- [10] Tomer Jordi Chaffer, Victor Jiawei Zhang, Sante Dino Facchini, Botao Amber Hu, Helena Rong, Zihan Guo, Xisen Wang, Carlos Santana, and Giovanni De Gasperis. Distributed legal infrastructure for a trustworthy agentic web. <https://arxiv.org/abs/2603.06884>, 2026. arXiv:2603.06884; SSRN 6344539.
- [11] David Elliott Bell and Leonard J LaPadula. Secure computer systems: Mathematical foundations. Technical Report MTR-2547, MITRE Corporation, 1973.
- [12] Dorothy E Denning. A lattice model of secure information flow. *Communications of the ACM*, 19(5):236–243, 1976.
- [13] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated LLM agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, 2024.
- [14] Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramer. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. In *Advances in Neural Information Processing Systems*, volume 37, 2024.

- [15] Sam Toyer, Olivia Watkins, Ethan Mendes, Justin Svegliato, Luke Bailey, Tiffany Wang, Isaac Ong, Karim El-maaroufi, Pieter Abbeel, Trevor Darrell, Alan Ritter, and Stuart Russell. Tensor trust: Interpretable prompt injection attacks from an online game. In *Advances in Neural Information Processing Systems*, volume 37, 2024.
- [16] Sander Schulhoff, Jeremy Pinto, Ansum Khan, Louis-François Bouchard, Chenglei Si, Sidahmed Anati, Naty Tagber, Marzena Karpinska, Brieuc Dolan, and Jordan Boyd-Graber. Hackaprompt: An adversarial prompt engineering competition. In *Findings of the Association for Computational Linguistics: EMNLP 2023*, 2024.
- [17] Prince Zizhuang Wang and Shuli Jiang. AgentSocialBench: Evaluating privacy risks in human-centered agentic social networks. *arXiv preprint arXiv:2604.01487*, 2026.
- [18] Amr Gomaa, Ahmed Salem, and Sahar Abdelnabi. Converse: Benchmarking contextual safety in agent-to-agent conversations. *arXiv preprint arXiv:2511.05359*, 2025.
- [19] Gurusha Juneja, Jayanth Naga Sai Pasupulati, Alon Albalak, Wenyue Hua, and William Yang Wang. MAGPIE: A benchmark for multi-agent contextual privacy evaluation. *arXiv preprint arXiv:2510.15186*, 2025.
- [20] Minjun Park, Donghyun Kim, Hyeonjong Ju, Seungwon Lim, Dongwook Choi, Taeyoon Kwon, Minju Kim, and Jinyoung Yeo. PAC-BENCH: Evaluating multi-agent collaboration under privacy constraints. *arXiv preprint arXiv:2604.11523*, 2026.
- [21] Faouzi El Yagoubi, Godwin Badu-Marfo, and Ranwa Al Mallah. AgentLeak: A full-stack benchmark for privacy leakage in multi-agent LLM systems. *arXiv preprint arXiv:2602.11510*, 2026.
- [22] Keegan Hines, Gary Lopez, Matthew Hall, Federico Zarfati, Yonatan Zunger, and Emre Kiciman. Defending against indirect prompt injection attacks with spotlighting. *arXiv preprint arXiv:2403.14720*, 2024. Microsoft.
- [23] Eric Wallace, Kai Xiao, Reimar Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The instruction hierarchy: Training LLMs to prioritize privileged instructions. *arXiv preprint arXiv:2404.13208*, 2024. OpenAI.
- [24] Lei Wang, Wanyu Xu, Yihuai Lan, Zhiqiang Hu, Yunshi Lan, Roy Ka-Wei Lee, and Ee-Peng Lim. Plan-and-solve prompting: Improving zero-shot chain-of-thought reasoning by large language models. *Proceedings of the 61st Annual Meeting of the Association for Computational Linguistics*, 2023.
- [25] Kai Mei, Zelong Li, Shuyuan Xu, Ruosong Ye, Yingqiang Ge, and Yongfeng Zhang. AIOS: LLM agent operating system. *arXiv preprint arXiv:2403.16971*, 2025.
- [26] Zhiyong Wu, Chengcheng Han, Zichen Ding, Zhenmin Weng, Zhoumianze Liu, Shunyu Yao, Tao Yu, and Lingpeng Kong. Os-copilot: Towards generalist computer agents with self-improvement. *arXiv preprint arXiv:2402.07456*, 2024.
- [27] Qingyun Wu, Gagan Bansal, Jieyu Zhang, Yiran Wu, Beibin Li, Erkang Zhu, Li Jiang, Xu Zhang, Shaokun Zhang, Jiale Liu, et al. AutoGen: Enabling next-gen LLM applications via multi-agent conversation. *arXiv preprint arXiv:2308.08155*, 2023.
- [28] Sirui Hong, Mingchen Zhuge, Jonathan Chen, Xiawu Zheng, Yuheng Cheng, Ceyao Zhang, Jinlin Wang, Zili Wang, Steven Ka Shing Yau, Zijuan Lin, et al. Metagpt: Meta programming for a multi-agent collaborative framework. *arXiv preprint arXiv:2308.00352*, 2023.
- [29] Guohao Li, Hasan Abed Al Kader Hammoud, Hani Itani, Dmitrii Khizbullin, and Bernard Ghanem. Camel: Communicative agents for “mind” exploration of large language model society. *Advances in Neural Information Processing Systems*, 36, 2023.
- [30] Chen Qian, Xin Cong, Cheng Yang, Weize Chen, Yusheng Su, Juyuan Xu, Zhiyuan Liu, and Maosong Sun. Chatdev: Communicative agents for software development. *arXiv preprint arXiv:2307.07924*, 2023.
- [31] CrewAI. CrewAI: Framework for orchestrating role-playing AI agents. <https://www.crewai.com>, 2024.
- [32] LangChain Inc. LangChain: Building applications with LLMs through composability. <https://www.langchain.com>, 2023.
- [33] LangChain Inc. LangGraph: Building stateful, multi-actor applications with LLMs. <https://www.langchain.com/langgraph>, 2024.
- [34] Yashar Talebirad and Amirhossein Nadiri. Multi-agent collaboration: Harnessing the power of intelligent LLM agents. *arXiv preprint arXiv:2306.03314*, 2023.
- [35] Taicheng Guo, Xiuying Chen, Yaqi Wang, Ruidi Chang, Shichao Pei, Nitesh V Chawla, Olaf Wiest, and Xiangliang Zhang. Large language model based multi-agents: A survey of progress and challenges. *Proceedings of the Thirty-Third International Joint Conference on Artificial Intelligence*, 2024.

- [36] Joon Sung Park, Joseph C O'Brien, Carrie J Cai, Meredith Ringel Morris, Percy Liang, and Michael S Bernstein. Generative agents: Interactive simulacra of human behavior. In *Proceedings of the 36th Annual ACM Symposium on User Interface Software and Technology*, 2023.
- [37] Xisen Wang and Qi Zhang. Revisiting boids for emergent intelligence via multi-agent collaborative tool-building. <https://openreview.net/forum?id=46LJ81Yqm2>, 2025. SEA @ NeurIPS 2025 Poster.
- [38] Andres M. Bran, Sam Cox, Oliver Schilter, Carlo Baldassari, Andrew D. White, and Philippe Schwaller. Augmenting large language models with chemistry tools. *Nature Machine Intelligence*, 6:525–535, 2024. doi: 10.1038/s42256-024-00832-8. URL <https://www.nature.com/articles/s42256-024-00832-8>.
- [39] Yuante Li, Xu Yang, Xiao Yang, Minrui Xu, Xisen Wang, Weiqing Liu, and Jiang Bian. R&D-Agent-Quant: A multi-agent framework for data-centric factors and model joint optimization, 2025. URL <https://arxiv.org/abs/2505.15155>.
- [40] Foundation for Intelligent Physical Agents. Fipa acl message structure specification. Technical Report SC00061G, FIPA, 2002.
- [41] Fabio Luigi Bellifemine, Giovanni Caire, and Dominic Greenwood. *Developing Multi-Agent Systems with JADE*. Wiley, 2007.
- [42] John E Laird. *The Soar Cognitive Architecture*. MIT Press, 2012.
- [43] John R Anderson. *How Can the Human Mind Occur in the Physical Universe?* Oxford University Press, 2007. Describes the ACT-R cognitive architecture.
- [44] Stuart J Russell and Peter Norvig. *Artificial Intelligence: A Modern Approach*. Pearson, 4th edition, 2020.
- [45] OpenAI. Gpt-4 technical report. arXiv preprint arXiv:2303.08774, 2023.
- [46] Anthropic. The claude model family: Claude 3 opus, sonnet, and haiku. <https://www.anthropic.com/claude>, 2024.
- [47] Xiao Liu, Hao Yu, Hanchen Zhang, et al. Agentbench: Evaluating llms as agents. In *International Conference on Learning Representations*, 2024.
- [48] Shunyu Yao, Howard Chen, John Yang, and Karthik Narasimhan. Webshop: Towards scalable real-world web interaction with grounded language agents. *Advances in Neural Information Processing Systems*, 35, 2022.
- [49] Shuyan Zhou, Frank F Xu, Hao Zhu, Xuhui Zhou, Robert Lo, Abishek Sridhar, Xianyi Cheng, Yonatan Bisk, Daniel Fried, Uri Alon, et al. Webarena: A realistic web environment for building autonomous agents. *arXiv preprint arXiv:2307.13854*, 2024.
- [50] Carlos E Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. Swe-bench: Can language models resolve real-world github issues? *arXiv preprint arXiv:2310.06770*, 2024.
- [51] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *arXiv preprint arXiv:2302.12173*, 2023.
- [52] Yi Liu, Gelei Deng, Yuekang Li, Kailong Wang, et al. Prompt injection attack against LLM-integrated applications. *arXiv preprint arXiv:2306.05499*, 2023.
- [53] Tongxin Yuan, Zhiwei He, Lingzhong Dong, et al. R-judge: Benchmarking safety risk awareness for llm agents. In *Findings of the Association for Computational Linguistics: EMNLP 2024*, 2024.
- [54] Ishan Kavathekar, Hemang Jain, Ameya Rathod, Ponnurangam Kumaraguru, and Tanuja Ganu. TAMAS: Benchmarking adversarial risks in multi-agent LLM systems. *arXiv preprint arXiv:2511.05269*, 2025.
- [55] Shouju Wang, Fenglin Yu, Xirui Liu, Xiaoting Qin, Jue Zhang, Qingwei Lin, Dongmei Zhang, and Saravan Rajmohan. Privacy in action: Towards realistic privacy mitigation and evaluation for LLM-powered agents. In *Findings of the Association for Computational Linguistics: EMNLP 2025*, 2025.
- [56] Ya-Ting Yang and Quanyan Zhu. Differential privacy in generative ai agents: Analysis and optimal tradeoffs. *arXiv preprint arXiv:2603.17902*, 2026.
- [57] Natalie Shapira, Chris Wendler, Avery Yen, et al. Agents of chaos. *arXiv preprint arXiv:2602.20021*, 2026.
- [58] Andy Zou, Zifan Wang, J Zico Kolter, and Matt Fredrikson. Universal and transferable adversarial attacks on aligned language models. *arXiv preprint arXiv:2307.15043*, 2023.

- [59] Xiaogeng Liu, Nan Xu, Muhao Chen, and Chaowei Xiao. Autodan: Generating stealthy jailbreak prompts on aligned large language models. In *International Conference on Learning Representations*, 2024.
- [60] Patrick Chao, Alexander Robey, Edgar Dobriban, Hamed Hassani, George J Pappas, and Eric Wong. Jailbreaking black box large language models in twenty queries. In *IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, 2025.
- [61] Yi Zeng, Hongpeng Lin, Jingwen Zhang, Diyi Yang, Ruoxi Jia, and Weiyan Shi. How johnny can persuade LLMs to jailbreak them: Rethinking persuasion to challenge AI safety by humanizing LLMs. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics*, 2024.
- [62] Anay Mehrotra, Manolis Zampetakis, Paul Kassianik, Blaine Nelson, Hyrum Anderson, Yaron Singer, and Amin Karbasi. Tree of attacks: Jailbreaking black-box LLMs automatically. In *Advances in Neural Information Processing Systems*, volume 37, 2024.
- [63] Mark Russinovich, Ahmed Salem, and Ronen Eldan. Great, now write an article about that: The crescendo multi-turn LLM jailbreak attack. In *USENIX Security Symposium*, 2025.
- [64] Cem Anil, Esin Durmus, Mrinank Sharma, Joe Benton, et al. Many-shot jailbreaking. 2024. Anthropic Research.
- [65] Alexander Wei, Nika Haghtalab, and Jacob Steinhardt. Jailbroken: How does LLM safety training fail? *Advances in Neural Information Processing Systems*, 36, 2023.
- [66] Johann Rehberger. Scary agent skills: Hidden unicode instructions in skills and how to catch them. Embrace The Red Blog, <https://embracethered.com/blog/posts/2026/scary-agent-skills/>, 2026.
- [67] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. Struq: Defending against prompt injection with structured queries. In *USENIX Security Symposium*, 2025.
- [68] Hakan Inan, Kartikeya Upasani, Jianfeng Chi, et al. Llama Guard: LLM-based input-output safeguard for human-AI conversations. *arXiv preprint arXiv:2312.06674*, 2023. Meta.
- [69] Traian Rebedea, Razvan Dinu, Makesh Narsimhan Sreedhar, Christopher Parisien, and Jonathan Cohen. NeMo Guardrails: A toolkit for controllable and safe LLM applications with programmable rails. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing: System Demonstrations*, 2023.
- [70] Yuntao Bai, Saurav Kadavath, Sandipan Kundu, Amanda Askell, Jackson Kernion, Andy Jones, Anna Chen, Anna Goldie, Azalia Mirhoseini, Cameron McKinnon, et al. Constitutional ai: Harmlessness from ai feedback. *arXiv preprint arXiv:2212.08073*, 2022.
- [71] Shaona Ghosh, Barnaby Simkin, Kyriacos Shiarlis, Soumili Nandi, Dan Zhao, Matthew Fiedler, Julia Bazinska, Nikki Pope, Roopa Prabhu, Daniel Rohrer, Michael Demoret, and Bartley Richardson. A safety and security framework for real-world agentic systems. *arXiv preprint arXiv:2511.21990*, 2025.
- [72] Meta AI. The rule of two: A security framework for ai agents. Meta AI Blog, 2025.
- [73] Anthropic. Prompt injection defenses in claude. Anthropic Research Blog, 2025.
- [74] Google DeepMind. A five-layer defense against prompt injection. Google Security Blog, 2025.
- [75] Steve Wilson et al. Owasp top 10 for large language model applications 2025. <https://genai.owasp.org>, 2024.
- [76] Milad Nasr, Nicholas Carlini, Chawin Sitawarin, Sander V. Schulhoff, Jamie Hayes, Michael Ilie, Juliette Pluto, Shuang Song, Harsh Chaudhari, Ilia Shumailov, Abhradeep Thakurta, Kai Yuanqing Xiao, Andreas Terzis, and Florian Tramèr. The attacker moves second: Stronger adaptive attacks bypass defenses against LLM jailbreaks and prompt injections. *arXiv preprint arXiv:2510.09023*, 2025.
- [77] Jack B Dennis and Earl C Van Horn. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 9(3):143–155, 1966.
- [78] Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, et al. Extracting training data from large language models. In *USENIX Security Symposium*, 2021.
- [79] Nicholas Carlini, Daphne Ippolito, Matthew Jagielski, Katherine Lee, Florian Tramèr, and Chiyuan Zhang. Quantifying memorization across neural language models. In *International Conference on Learning Representations*, 2023.
- [80] Cynthia Dwork. Differential privacy. *International Colloquium on Automata, Languages, and Programming*, pages 1–12, 2006.

- [81] Haoran Li, Dadi Chen, Donghao Luo, et al. Privacy in large language models: Attacks, defenses and future directions. *arXiv preprint arXiv:2310.10383*, 2023.
- [82] Vaidehi Patil, Elias Stengel-Eskin, and Mohit Bansal. The sum leaks more than its parts: Compositional privacy risks and mitigations in multi-agent collaboration. *arXiv preprint arXiv:2509.14284*, 2025.
- [83] Ronald H Coase. The nature of the firm. *Economica*, 4(16):386–405, 1937.
- [84] Oliver E Williamson. *Markets and Hierarchies: Analysis and Antitrust Implications*. Free Press, 1975.
- [85] Mark S Granovetter. The strength of weak ties. *American Journal of Sociology*, 78(6):1360–1380, 1973.